

RAPPORT TECHNIQUE TP 2-2: ANALYSE ET CORRECTION DES VULNERABILITES (ENVIRONNEMENTS LINUX ET WINDOWS)

1. Introduction et Objectifs

Ce travail pratique marque la transition entre la phase de diagnostic et l'intervention directe sur les systèmes. L'objectif principal consistait à traiter les failles critiques détectées précédemment sur les machines Ubuntu et Windows. En suivant le cycle de vie de la gestion des vulnérabilités **identification, analyse, remédiation et contrôle**. Ce TP visait à renforcer la sécurité via des mises à jour applicatives, le durcissement du pare-feu et l'optimisation des services actifs.

2. Analyse Technique des Vulnérabilités Sélectionnées

Quatre vulnérabilités majeures identifiées lors du scan initial ont été retenues pour une étude approfondie.

Environnement Linux

- ❖ **CVE-2021-3156 (Sudo Baron Samedit)** : Un dépassement de tampon (*buffer overflow*) situé dans la fonction `set_cmd()` de l'utilitaire `sudo`. Elle permet à un utilisateur non privilégié d'obtenir des droits root.
- ❖ **CVE-2022-0847 (Dirty Pipe)** : Une faille de haute priorité touchant le noyau Linux. Elle exploite l'appel système `splice()` pour corrompre les données dans les conduits de communication (pipes), permettant l'écriture de données dans des fichiers normalement en lecture seule.

Environnement Windows

- ❖ **CVE-2021-34527 (PrintNightmare)** : Une faille critique dans le spouleur d'impression liée à une vérification insuffisante des pilotes via le protocole RPC.
- ❖ **CVE-2022-30190 (Follina)** : Une vulnérabilité utilisant l'outil de diagnostic Microsoft (MSDT). Elle permet l'exécution de code à distance via des documents Office malveillants, même sans l'activation de macros.

3. Protocole de Remédiation sur Ubuntu

Le durcissement de la machine Ubuntu a été réalisé en trois étapes clés:
La correction des vulnérabilités sur la machine Ubuntu a suivi une approche systématique en trois phases : mise à jour complète du système, désactivation des services inutiles et durcissement du pare-feu.

A. Maintenance et Mises à jour

1. **Synchronisation** : La première étape a consisté à rafraîchir la liste des paquets disponibles depuis les dépôts officiels pour synchroniser les index des paquets avec les dépôts Ubuntu, récupérant les informations sur les versions les plus récentes. Utilisation de `sudo apt update` pour actualiser la base de données des paquets.

```
bel-ange@bel-ange:~$ sudo apt update
[sudo] Mot de passe de bel-ange :
Ign : 1 http://archive.ubuntu.com/ubuntu plucky InRelease
Ign : 2 http://security.ubuntu.com/ubuntu plucky-security InRelease
Réception de : 2 http://security.ubuntu.com/ubuntu plucky-security InRelease [126 kB]
Réception de : 3 http://archive.ubuntu.com/ubuntu plucky-updates InRelease [126 kB]
Réception de : 4 http://archive.ubuntu.com/ubuntu plucky-backports InRelease [126 kB]
Réception de : 1 http://archive.ubuntu.com/ubuntu plucky InRelease [265 kB]
Réception de : 5 http://archive.ubuntu.com/ubuntu plucky-updates/main i386 Packages [226 kB]
Réception de : 6 http://security.ubuntu.com/ubuntu plucky-security/main amd64 Packages [233 kB]
Réception de : 7 http://archive.ubuntu.com/ubuntu plucky-updates/main amd64 Packages [358 kB]
Réception de : 8 http://security.ubuntu.com/ubuntu plucky-security/main i386 Packages [144 kB]
Réception de : 9 http://security.ubuntu.com/ubuntu plucky-security/main Translation-en [68,7 kB]
Réception de : 10 http://archive.ubuntu.com/ubuntu plucky-updates/main Translation-en [105 kB]
Réception de : 11 http://archive.ubuntu.com/ubuntu plucky-updates/main amd64 Com
```

2. **Mise à niveau logicielle** : Exécution de `sudo apt upgrade -y`, ce qui a permis de passer `sudo` en version 1.8.31, neutralisant ainsi la CVE-2021-3156.

```
bel-ange@bel-ange:~$ sudo apt upgrade -y
[sudo] Mot de passe de bel-ange :
Mis à jour :
  alsa-ucm-conf
  amd64-microcode
  apache2
  apache2-bin
  apache2-data
  apache2-utils
  apparmor
  apport
  apport-core-dump-handler
  apport-gtk
  bind9-dnsutils
  bind9-host
  bind9-libs
  binutils
  binutils-common
  binutils-x86-64-linux-gnu
```

3. **Mise à jour du noyau** : Application de `sudo apt dist-upgrade -y` pour installer la version 5.15.0 du kernel, corrigeant la faille "Dirty Pipe".

```
bel-ange@bel-ange:~$ sudo apt dist-upgrade -y
[sudo] Mot de passe de bel-ange :
Mis à jour :
  alsa-ucm-conf
  amd64-microcode
  apache2
  apache2-bin
  apache2-data
  apache2-utils
  apparmor
  apport
  apport-core-dump-handler
  apport-gtk
  bind9-dnsutils
  bind9-host
  bind9-libs
  binutils
  binutils-common
  binutils-x86-64-linux-gnu
  bluez
  bluez-cups
  bluez-obexd
  bpftool
  bsdextrautils
```

4. **Nettoyage** : Suppression des composants obsolètes via `sudo apt autoremove -y`.

```
bel-ange@bel-ange:~$ sudo apt autoremove -y
[sudo] Mot de passe de bel-ange :
Sommaire :
  Mise à niveau de : 0. Installation de : 0Supprimé : 0. Non mis à jour : 383
bel-ange@bel-ange:~$
```

5. Désactivation des services inutiles

- ❖ Une analyse des services actifs a été réalisée avec `systemctl list-units --type=service -state=running`. Cette commande a affiché l'ensemble des services en cours d'exécution, avec leurs noms, leurs statuts et leurs descriptions

```
bel-ange@bel-ange:~$ systemctl list-units --type=service --state=running
```

UNIT	LOAD	ACTIVE	SUB	DESCRIPTION
accounts-daemon.service	loaded	active	running	Accounts Service
apache2.service	loaded	active	running	The Apache HTTP Server
avahi-daemon.service	loaded	active	running	Avahi mDNS/DNS-SD Stack
colord.service	loaded	active	running	Manage, Install and Gener>
cron.service	loaded	active	running	Regular background progra>
cups-browsed.service	loaded	active	running	Make remote CUPS printers>
cups.service	loaded	active	running	CUPS Scheduler
dbus.service	loaded	active	running	D-Bus System Message Bus
fwupd.service	loaded	active	running	Firmware update daemon
gdm.service	loaded	active	running	GNOME Display Manager
gnome-remote-desktop.service	loaded	active	running	GNOME Remote Desktop
ModemManager.service	loaded	active	running	Modem Manager
NetworkManager.service	loaded	active	running	Network Manager
polkit.service	loaded	active	running	Authorization Manager
power-profiles-daemon.service	loaded	active	running	Power Profiles daemon
rsyslog.service	loaded	active	running	System Logging Service
rtkit-daemon.service	loaded	active	running	RealtimeKit Scheduling Po>
snapd.service	loaded	active	running	Snap Daemon

- ❖ Le service Cups (Common UNIX Printing System), qui gère l'impression, a été identifié comme non nécessaire sur cette machine. Il a été arrêté immédiatement

avec **sudo systemctl stop cups**, puis désactivé définitivement pour empêcher tout redémarrage automatique avec **sudo systemctl disable cups**. La désactivation de ce service réduit la surface d'attaque en supprimant un vecteur potentiel d'exploitation lié aux imprimantes réseau.

```
bel-ange@bel-ange:~$ sudo systemctl stop cups
[sudo] Mot de passe de bel-ange :
bel-ange@bel-ange:~$ sudo systemctl disable cups
Synchronizing state of cups.service with SysV service script with /usr/lib/systemd/systemd-sysv-install.
Executing: /usr/lib/systemd/systemd-sysv-install disable cups
Removed '/etc/systemd/system/printer.target.wants/cups.service'.
Removed '/etc/systemd/system/multi-user.target.wants/cups.service'.
Removed '/etc/systemd/system/multi-user.target.wants/cups.path'.
Removed '/etc/systemd/system/sockets.target.wants/cups.socket'.
```

B. Restriction des Services

L'examen des processus actifs via **systemctl** a révélé que le service d'impression **CUPS** était inutile pour ce serveur. Il a été stoppé et désactivé pour éliminer ce vecteur d'attaque potentiel.

C. Sécurisation Réseau (UFW)

Configuration du pare-feu UFW

Le pare-feu UFW (Uncomplicated Firewall) a été configuré pour limiter les accès entrants. La commande **sudo ufw enable** a activé le pare-feu. La politique par défaut a été définie avec **sudo ufw default deny incoming** pour bloquer toutes les connexions entrantes non autorisées, et **sudo ufw default allow outgoing** pour autoriser les connexions sortantes.

Le pare-feu **UFW** a été configuré avec une politique de sécurité restrictive:

- ❖ Activation du pare feu

```
bel-ange@bel-ange:~$ sudo ufw enable
Le pare-feu est actif et lancé au démarrage du système
```

- ❖ **Flux entrants** : Bloqués par défaut (*deny incoming*).

```
bel-ange@bel-ange:~$ sudo ufw default deny incoming
La stratégie par défaut pour le sens « incoming » a été remplacée par « deny »
(veillez à mettre à jour vos règles en conséquence)
```

- ❖ **Flux sortants** : Autorisés par défaut (*allow outgoing*).

```
bel-ange@bel-ange:~$ sudo ufw default allow outgoing
La stratégie par défaut pour le sens « outgoing » a été remplacée par « allow »
(veillez à mettre à jour vos règles en conséquence)
```

- ❖ **Exception** : Seul le port 22/TCP (SSH) a été ouvert pour l'administration à distance.

```
bel-ange@bel-ange:~$ sudo ufw allow 22/tcp
Omission de l'ajout de la règle existante
Omission de l'ajout de la règle existante (v6)
```

- ❖ L'état final a été validé avec `sudo ufw status verbose.`, qui a affiché le statut actif, les politiques par défaut et la liste des règles.

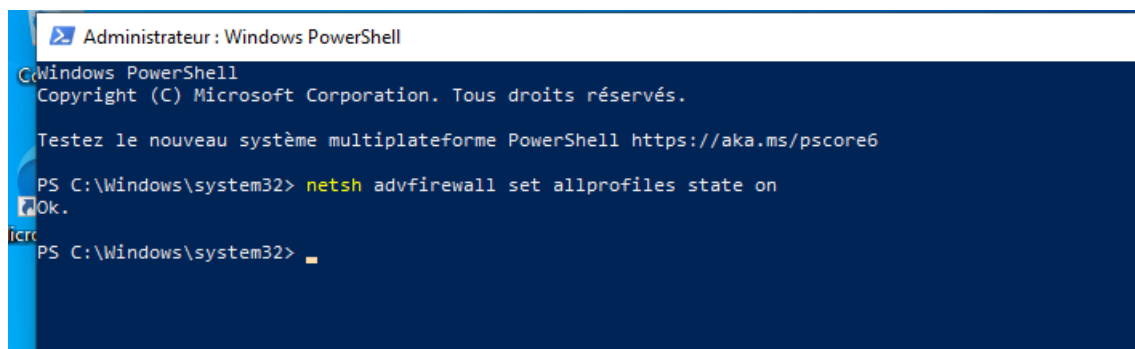
```
bel-ange@bel-ange:~$ sudo ufw status verbose
État : actif
Journalisation : on (low)
Par défaut : deny (incoming), allow (outgoing), disabled (routed)
Nouveaux profils : skip

Vers          Action      De
----          -
22/tcp        ALLOW IN    Anywhere
80/tcp        ALLOW IN    Anywhere
22/tcp (v6)   ALLOW IN    Anywhere (v6)
80/tcp (v6)   ALLOW IN    Anywhere (v6)
```

4. Protocole de Remédiation sur Windows

La sécurisation de l'hôte Windows a suivi une méthodologie adaptée aux outils Microsoft.

- ❖ **Pare-feu** : Activation globale via PowerShell avec la commande `netsh advfirewall set allprofiles state on.`



```
Administrateur : Windows PowerShell
C:\Windows PowerShell
Copyright (C) Microsoft Corporation. Tous droits réservés.

Testez le nouveau système multiplateforme PowerShell https://aka.ms/pscore6

PS C:\Windows\system32> netsh advfirewall set allprofiles state on
Ok.

PS C:\Windows\system32>
```

- ❖ **Windows Update** : Exécution répétée des cycles de mise à jour dans les paramètres système jusqu'à l'obtention d'un état totalement patché.
- ❖ **Gestion des Services** : Utilisation de `services.msc` pour désactiver manuellement le **Spouleur d'impression**, prévenant ainsi les risques liés à PrintNightmare.

5. Évaluation des Résultats et Analyse Comparative

Un second audit avec **Nessus** ("Rescan_Apres_Correction") a été effectué pour mesurer l'impact des mesures prises. Les scans montrent une réduction drastique des vulnérabilités critiques.

Interprétation de la Capacité de Gestion

Sur l'échelle de maturité du cours, le score de gestion est passé d'une valeur négative à une valeur positive. Cela témoigne d'une meilleure organisation et d'un contrôle accru sur l'infrastructure.

Néanmoins, la persistance de certaines failles mineures sur Windows démontre qu'une sécurité parfaite est illusoire. Il est impératif d'adopter une stratégie de **défense en profondeur**, incluant la surveillance continue et la segmentation réseau.

6. Conclusion

Ce TP a permis de valider le cycle complet de sécurisation : de la découverte à la vérification des correctifs. Si les actions de mise à jour et de filtrage sont efficaces, la sécurité reste un processus dynamique nécessitant une veille permanente face aux vulnérabilités résiduelles.